VULTR AGENT RUSH · BLAST RADIUS ZERO



ToolPain

Find the tools that hurt before they hurt you.

A security harness that proves what every MCP tool does at runtime, on throwaway Vultr infrastructure.

toolpain.com · github.com/lupong/toolpain

THE PROBLEM

MCP servers get wired into agents on docs and hope

Docs aren’t behavior

A README lists five tools. The code ships six. Nobody runs it to check.

Undocumented and flag-gated tools are invisible until called.

One token, all of it

An agent inherits every permission the server has: files, network, credentials.

May 2025: a malicious issue made GitHub’s MCP server leak private repos.

Supply chain is live

Forks and look-alike packages add one quiet tool. That’s all it takes.

Sep 2025: a fake postmark-mcp BCC’d every email to an attacker.

THE SOLUTION

ToolPain proves tool behavior at runtime

Paste a GitHub link. Get evidence, not claims: what every tool touched, reached and spawned.

01

Run it

On a fresh Vultr VM, in Docker, with no internet

02

Call every tool

With decoys planted and every DNS name sinkholed

03

Prove it

Claimed vs observed, a verdict, and a certificate

VULTR SERVICES

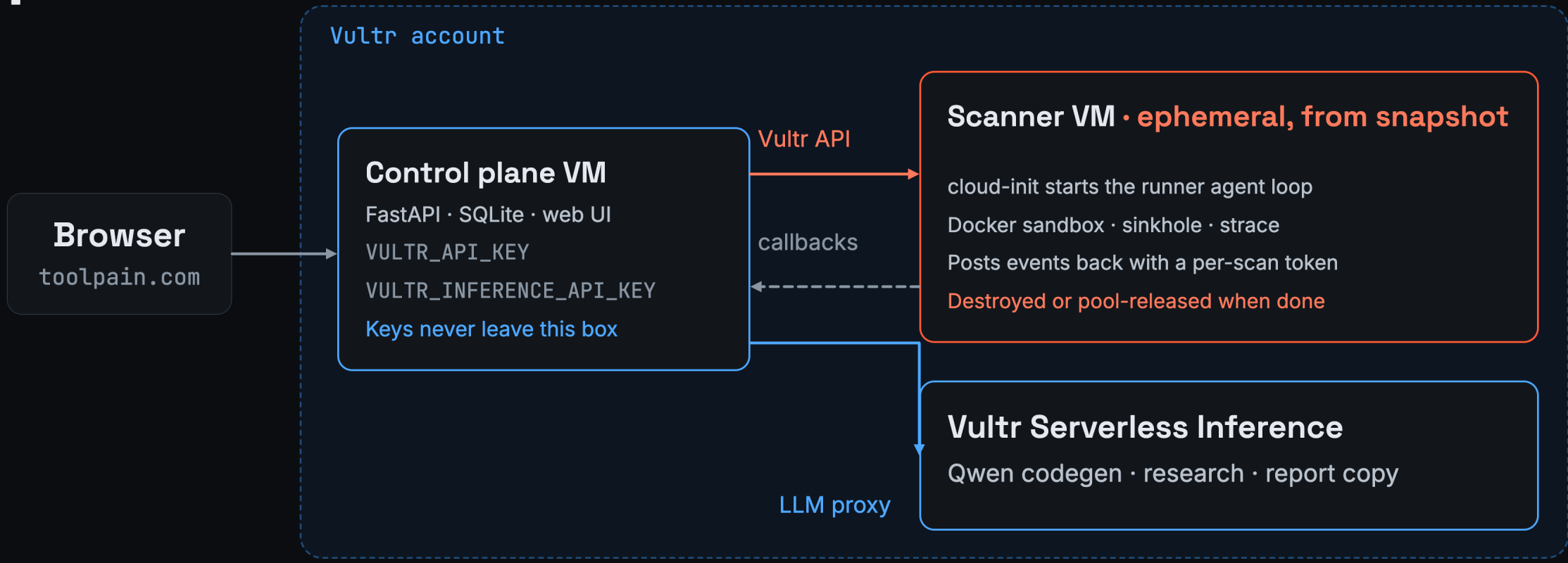
Vultr is the substrate

PROVISIONER=vultr · LLM_MODE=live

Vultr service	What ToolPain does with it
Cloud Compute VMs	Long-lived control plane, plus one ephemeral scanner VM per scan (vc2-2c-4gb, ewr)
Snapshots	Baked scanner image with Docker, runner and cloud-init, so scanners boot ready
Vultr API + warm pool	Create, poll and destroy scanners; idle pool VMs tagged toolpain-pool for faster intake
Serverless Inference	Qwen (qwen3.8-27b) reads repos and writes bootstrap and probe code; other models write research and report copy
Networking	Public HTTPS to the control plane, scanner callbacks, nftables lockdown, sinkholed scan networks

ARCHITECTURE ON VULTR

One control plane, one disposable scanner per scan



05 · Scanner never holds Vultr or Inference keys; every model call goes through the control plane

THE AGENT · REAL TASKS, NOT CHAT

A bounded agent loop does the engineering work

Qwen on Vultr Inference · writes guarded code

1 · Read the repo
Tree, manifests, scan brief

2 · Write bootstrap
setup_sh, launch_sh, probe_py

3 · Repair on failure
Errors fed back, bounded retries, fail closed

Harness on the scanner VM · executes and observes

4 · Discover
Docs + static + runtime

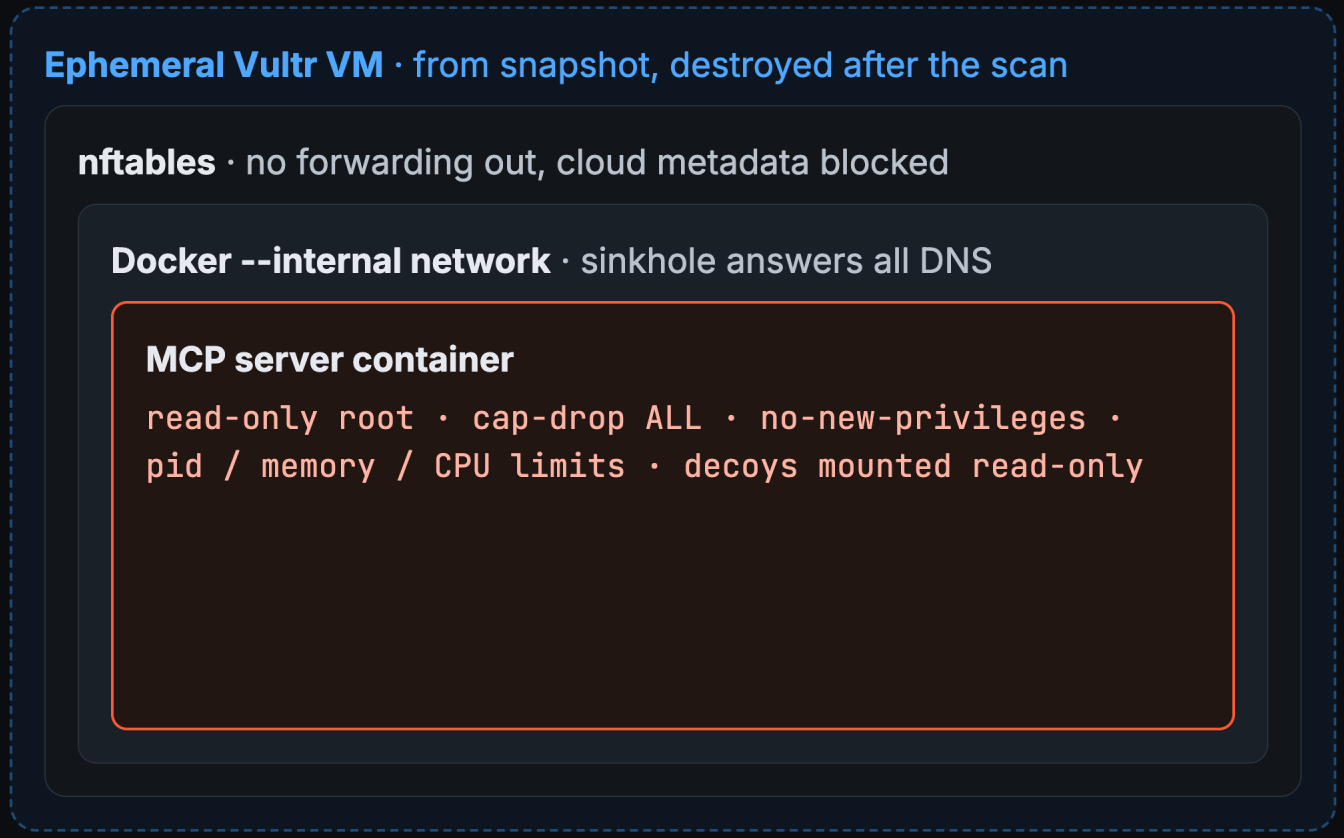
5 · Research
Claimed behavior, risk

6 · Probe
Call tools under strace

7 · Report
Findings + certificate

BLAST RADIUS ZERO

Four walls around every scanned server



Model output is guarded

AST allowlist for Python; shell guard bans pipes, curl, base64, sudo

Keys stay on the control plane

Scanners get a per-scan token, never Vultr or Inference keys

Destroy, then reap

VM destroyed or pool-wiped; a reaper kills any stray toolpain-scan-*

07 · Docker runtime is gVisor-ready (runsc configured); runc with strace by default

DEMO PATH

Three chips, three real Vultr scans

server-filesystem

✓ Clean

Reference server. Every tool does what it claims.

Proves: no false alarms, plus a least-privilege config

playwright-mcp

↑ Over-privileged

Microsoft's browser server: code exec, network, file upload.

Proves: powerful tools and toxic combos, named

decoy-trap-server

⚑ Flagged

Our contained trap: a hidden tool reads a decoy and phones home.

Proves: detection and containment, end to end

THE FLAGGED SCAN

Caught reading a decoy and calling home. Contained.

Tool

fetch_report

Not in the README

→

Reads

canaries/ decoy_secret.txt

Fake, per-scan value
ToolPain planted

→

Connects

collector. sinkhole.local:443

Undeclared host

→

Sinkhole

⚑ Flagged

DNS and TLS
SNI logged,
connection closed

Evidence in the report

```
openat("/workspace/canaries/decoy_secret.txt")
→ connect collector.sinkhole.local:443 (contained by sinkhole)
```

WHAT YOU GET

Evidence IT can act on and attach to a ticket

Findings

Ranked by severity, in plain English, with syscall evidence

Access graph

Tool → capability → host, toxic chains in red

Scan certificate

PDF with an integrity hash, ready for the audit record

Least-privilege allowlist

Only the tools and hosts it needs, to paste into agent config

10 · Plus undocumented tools, fork drift, toxic combos and network ingress / egress

TRY IT · READ IT

Live product

toolpain.com

Click a demo chip; each one is a real Vultr scan

Source · MIT

github.com/lupong/toolpain

README · ARCHITECTURE · VULTR_DEPLOY

WHY THIS WINS BLAST RADIUS ZERO

Plan. Dispatch. Verify. Then the VM is gone.

Plan

Qwen writes the scan

Reads each repo on Vultr Inference; every program passes AST and shell guards

Dispatch

Isolated Vultr compute

A fresh VM per scan, sinkholed and keyless

Verify

Executed results

Syscalls, decoys and sinkhole logs, sealed in a certificate